

# A Governed Zero Trust AI Gateway

*Private AI. Strong identity. Scoped knowledge. Auditable access. Clean offboarding.*

## The Problem

Most AI deployments trade governance for speed. Shared API keys, no per-user identity, no audit trail, no offboarding procedure. When an engagement ends, access persists until someone revokes it.

Self-hosted AI solves the sovereignty problem but introduces new gaps: inference without identity enforcement, ungoverned knowledge access, and no session controls. Capability without governance is not a security posture.

## What Was Built

- Tailscale WireGuard mesh: peer-to-peer where possible, encrypted DERP fallback
- Nginx Proxy Manager with auth\_request: Zero Trust enforcement point
- Authelia MFA: WebAuthn, Touch ID, TOTP before any AI access
- **OpenWebUI**: role-scoped RAG KB access, per-user conversation audit trail
- Ollama on MacBook Air M4: local inference, no third-party data exposure
- pf firewall: Ollama API restricted to localhost and Umbrel only, enforced at boot via LaunchDaemon
- AdGuard Home with Quad9 DoH: DNS filtering and encrypted upstream resolution
- D5 offboarding: 3-step revocation across Tailscale, Authelia, and OpenWebUI
- **AI security lab**: prompt injection, RAG poisoning, and AIBOM recovery tests mapped to MITRE ATLAS and NIST AI RMF

**Result: Private AI access with device trust, MFA, scoped knowledge, audibility, and clean 4-step offboarding.**

## Zero Trust Controls at a Glance

| Identity                                                                                                                                                                 | Network                                                                                                                                                                       | Data                                                                                                                                                                           | Operations                                                                                                                                                                    |
|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <ul style="list-style-type: none"><li>• Authelia MFA</li><li>• WebAuthn / Touch ID / TOTP</li><li>• Admin-mediated provisioning</li><li>• Dual-step enrollment</li></ul> | <ul style="list-style-type: none"><li>• Tailscale WireGuard mesh</li><li>• No public exposure</li><li>• Device authorization required</li><li>• DERP relay fallback</li></ul> | <ul style="list-style-type: none"><li>• Role-scoped RAG KBs</li><li>• Conversation audit trail</li><li>• AIBOM-documented assets</li><li>• Instruction-augmented RAG</li></ul> | <ul style="list-style-type: none"><li>• -step offboarding</li><li>• pf firewall on inference API</li><li>• AdGuard DNS filtering</li><li>• LaunchDaemon persistence</li></ul> |

## Identity Provisioning Model (No Self-Service)

No user can self-provision. Every account requires direct administrator action across two systems before access is granted.

- Admin manually creates user in Authelia YAML file
- Hashed password delivered out of band to the user
- Admin SSHs into Authelia Docker container to retrieve enrollment OTP
- OTP delivered to user: completes MFA enrollment via WebAuthn, Touch ID, or TOTP
- Account becomes operational only after all steps complete
- Enforces administrator-mediated dual-step provisioning on every identity

## Known Gaps (Documented)

- Authelia SPOF: MacBook offline = OpenWebUI unreachable. MFA never fails open. Remediation: move to always-on host for service availability.
- Certificate lifecycle: manual renewal required before Aug 25 2026.
- Post-quantum: Curve25519 handshake not quantum-safe. PSK support tracked on Tailscale roadmap.
- No dynamic PDP: trust evaluation is administrator-mediated at provisioning. Dynamic per-request evaluation is a future phase item.
- STRIDE threat model in progress: test surface map exists, data flow diagrams pending.